

Clase 190 — Análisis de logs de Windows: Event Logs y Sysmon

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases* — Don Murdoch 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Dominar los Event Logs nativos de Windows y Sysmon como fuente central de detección de endpoint. Aprenderás qué Event IDs importan, cómo desplegar y afinar una configuración de Sysmon, y cómo construir detecciones sobre creación de procesos, línea de comandos, conexiones de red, carga de DLLs y manipulación de registro.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Identificar** los Event IDs de seguridad más relevantes (4624, 4625, 4688, 4698, 4720...).
2. **Desplegar** y afinar una configuración de Sysmon para detección.
3. **Interpretar** los eventos Sysmon clave (1, 3, 7, 8, 11, 13, 22).
4. **Habilitar** y explotar el logging de PowerShell (ScriptBlock, Module).
5. **Escribir** detecciones sobre estos eventos y mapearlas a ATT&CK.

Temas

#	Tema	Por qué importa
1	Canales de Event Log de Windows	Dónde vive cada evento
2	Event IDs de autenticación (4624/4625)	Detectar fuerza bruta y accesos
3	Creación de procesos (4688 vs Sysmon 1)	Ver ejecución y línea de comandos
4	Sysmon: eventos clave y config	Telemetría rica de endpoint
5	PowerShell logging (4103/4104)	Cazar scripts y ofuscación
6	Persistencia (4698, 4657, Sysmon 12/13)	Detectar tareas y cambios de registro
7	Logon types y sesiones	Diferenciar interactivo, red, RDP
8	Afinado y reducción de ruido	Evitar ahogar el SIEM

Definiciones y características

- **Event ID 4624/4625:** logon exitoso/fallido. Característica: incluye *Logon Type* (2 interactivo, 3 red, 10 RDP) clave para el contexto.

- **Event ID 4688:** creación de proceso nativa. Característica: con auditoría de línea de comandos habilitada, registra el CommandLine.
- **Sysmon Event 1 (Process Create):** creación de proceso con hash, línea de comandos, proceso padre. Característica: más rico que 4688 y con integridad de linaje.
- **Sysmon Event 3 (Network Connection):** conexión de red por proceso. Característica: asocia tráfico saliente al binario responsable.
- **Sysmon Event 11/12/13:** creación de archivo y cambios de registro. Característica: detecta persistencia y drops.
- **Sysmon Event 22 (DNS Query):** consulta DNS por proceso. Característica: base para detectar C2/DGA.
- **PowerShell 4104 (ScriptBlock):** registra el bloque de script ejecutado, incluso ofuscado tras desofuscar. Característica: visibilidad crítica de ejecución.

Herramientas y preparación

- **Sysmon** con una configuración base robusta (p. ej. la de SwiftOnSecurity o la de Olaf Hartong como punto de partida) adaptada a tu entorno.
- **Directiva de auditoría** de Windows para habilitar 4688 con línea de comandos y logon auditing.
- **Módulo de PowerShell logging** activado por GPO (ScriptBlock y Module Logging).
- Tu SIEM (clases 184/185) recibiendo estos canales vía Winlogbeat/Universal Forwarder.

Practica en tu Windows de laboratorio; nunca en equipos ajenos.

Laboratorio guiado — De evento a detección

1. **Habilita auditoría.** Activa "Audit Process Creation" con inclusión de CommandLine (GPO: *Include command line in process creation events*).
2. **Despliega Sysmon.** `sysmon64.exe -accepteula -i config.xml`. Verifica el canal `Sysmon/Operational`.
3. **Activa PowerShell logging.** Por GPO habilita ScriptBlock (4104) y Module Logging (4103).
4. **Genera actividad.** Ejecuta: un logon fallido repetido (4625), `powershell -enc <base64 benigno>` (4104), y `schtasks /create benigno` (4698).
5. **Detecta autenticación anómala.** En el SIEM, cuenta 4625 por cuenta y `Logon Type`; alerta si hay ráfaga seguida de 4624.
6. **Detecta ejecución sospechosa.** Busca Sysmon Event 1 con `ParentImage` de Office e `Image` de intérprete; correlaciona con Event 3 (conexión) del mismo proceso.
7. **Detecta PowerShell ofuscado.** Sobre 4104, busca indicadores (`FromBase64String`, `-enc`, `IEX`, concatenaciones largas).
8. **Detecta persistencia.** Alerta ante 4698 (tarea) o Sysmon 13 (Run key) creados fuera de la ventana de mantenimiento.

Ejercicios

1. Mapea 8 Event IDs a su técnica ATT&CK correspondiente.
2. Explica los Logon Types 2, 3, 9 y 10 con un caso de uso de detección cada uno.
3. Afinar una config de Sysmon para excluir un proceso ruidoso legítimo.
4. Escribe una detección de "PowerShell descargando y ejecutando" (IEX + Net.WebClient).
5. Diferencia 4688 y Sysmon 1: ¿qué aporta cada uno?

6. Crea una regla para creación de cuenta local sospechosa (4720).

Reto verificable

Entrega tres detecciones basadas en Event Logs/Sysmon (autenticación, ejecución y persistencia) probadas en tu laboratorio, cada una con su Event ID, lógica y técnica ATT&CK. **Criterio de aceptación:** las tres disparan con la actividad que generas y no con la línea base; demuestras que capturas la línea de comandos completa (no truncada) del proceso sospechoso y su relación padre-hijo.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
4688 sin línea de comandos	Falta habilitar "Include command line"; actívalo por GPO
Sysmon genera ruido enorme	Config sin exclusiones; parte de una base afinada y filtra
No aparece PowerShell 4104	ScriptBlock logging desactivado; habilítalo por GPO
CommandLine truncado en SIEM	Límite de campo; ajusta truncation en el forwarder/props
Falsos positivos de tareas	Ventana de mantenimiento no excluida; añade filtro por horario/cuenta

Preguntas frecuentes

 **¿Sysmon o solo Event Logs nativos?** Sysmon añade hash, linaje íntegro, conexiones por proceso y DNS. Los nativos aportan autenticación y auditoría. La combinación es el estándar de facto del blue team.

 **¿PowerShell logging captura scripts ofuscados?** ScriptBlock (4104) registra el bloque tras des-ofuscar en muchos casos, revelando la intención real. Es una de las fuentes más valiosas contra ataques modernos.

 **¿Cómo evito que Sysmon sature el SIEM?** Parte de una configuración comunitaria afinada, excluye procesos benignos ruidosos y prioriza los eventos con valor de detección (1, 3, 7, 11, 13, 22).

Referencias

- Microsoft Sysmon — <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- Windows Security Audit Events — <https://learn.microsoft.com/windows/security/threat-protection/auditing/>
- Olaf Hartong, sysmon-modular — <https://github.com/olafhartong/sysmon-modular>
- SwiftOnSecurity, sysmon-config — <https://github.com/SwiftOnSecurity/sysmon-config>
- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.

Siguiente clase

Clase 191 - Analisis de logs de red y proxy